

Risk Assessment Methodology : VertexOne Digital Services

Document Status: Draft for GRC Manager Review

Prepared By: Junior GRC Analyst

Reference: ISO/IEC 27001:2022 Clause 6.1

1. Purpose

This document defines VertexOne Digital Services' approach to identifying, analyzing, evaluating, and treating information security risks.

The methodology is designed to support a consistent and repeatable risk assessment process aligned with the requirements of **ISO/IEC 27001:2022 Clause 6.1**.

2. Methodology Overview

VertexOne Digital Services uses a **semi-quantitative risk assessment approach**.

Risk is calculated using the following formula:

Risk Score = Likelihood × Impact

Both Likelihood and Impact are scored on a scale of **1 to 5**.

Risk Score Range: 1–25

The resulting score is mapped to a defined risk rating band: Low, Medium, High, or Critical.

3. Likelihood Scale

Score	Rating	Description
1	Rare	May occur only in exceptional circumstances.
2	Unlikely	Could occur but is not expected.
3	Possible	Might occur at some point.
4	Likely	Will probably occur.
5	Almost Certain	Expected to occur, potentially multiple times per year.

4. Impact Scale

Score	Rating	Description
1	Negligible	Minimal effect on operations or reputation.
2	Minor	Limited effect that can be quickly resolved.
3	Moderate	Noticeable disruption or limited data exposure.
4	Major	Significant disruption, contractual exposure, or regulatory exposure.
5	Severe	Reportable breach, major financial loss, or significant reputational damage.

5. Risk Rating Bands

Risk Score	Rating
1–6	Low
7–12	Medium
13–19	High
20–25	Critical

The calculated risk score determines the initial risk rating and supports prioritization of risk treatment activities.

6. Inherent and Residual Risk

6.1 Inherent Risk

Inherent risk represents the level of risk before considering the effectiveness of existing security controls.

It reflects the potential exposure associated with a threat, vulnerability, asset, or business process in the absence of mitigating controls.

6.2 Residual Risk

Residual risk represents the level of risk remaining after existing or planned security controls are considered.

Any reduction between inherent and residual risk should be supported by documented evidence of the relevant controls and their effectiveness.

The specific control(s) responsible for reducing the risk should be referenced in the Risk Register.

7. Roles and Responsibilities

Role	Responsibility
GRC Manager	Responsible for coordinating, conducting, and documenting risk assessments.
CISO	Accountable for the overall risk assessment process and its outcomes.
Risk Committee	Reviews and approves significant risk treatment decisions and risk acceptance.
Asset Owners	Provide input regarding likelihood, impact, business context, and existing controls associated with their assets.

8. Risk Reassessment Cadence

VertexOne Digital Services formally reassesses information security risks:

- **Annually** as part of the organization's scheduled risk assessment cycle.
- **Following significant changes** to an asset, system, process, technology, or business environment.
- **Following significant changes to the threat landscape** that could materially affect existing risks.
- **Following a security incident** affecting an in-scope asset or process.
- **When significant control changes** may materially alter the existing risk level.

Risk assessments may also be performed when requested by the CISO, GRC Manager, or Risk Committee.

9. Risk ID Convention

All identified information security risks are assigned a unique sequential **Risk ID** using the following convention:

R-001, R-002, R-003, and so on.

Risk IDs are maintained consistently across relevant ISMS documentation, including:

- Risk Register
- Risk Treatment Plan
- Statement of Applicability (SoA)
- Control Register
- Internal Audit documentation
- Other downstream ISMS artifacts

Once assigned, a Risk ID should not be reused for a different risk.

10. Risk Assessment Process

VertexOne follows the following general risk assessment sequence:

- 1. Identify Asset / Process**
↓
- 2. Identify Threat and Vulnerability**
↓
- 3. Assess Likelihood (1–5)**
↓
- 4. Assess Impact (1–5)**
↓
- 5. Calculate Risk Score**
↓
- 6. Determine Risk Rating**
↓
- 7. Identify Existing Controls**
↓
- 8. Determine Residual Risk**
↓
- 9. Select Risk Treatment**
↓
- 10. Document and Approve Treatment**

This process provides a consistent basis for prioritizing information security risks and selecting appropriate risk treatment actions.

11. Risk Treatment

Depending on the assessed risk and organizational context, VertexOne may select one or more of the following risk treatment options:

Treatment Option	Description
Risk Modification	Implement or strengthen controls to reduce likelihood and/or impact.
Risk Avoidance	Stop or change the activity that creates the unacceptable risk.
Risk Sharing	Transfer or share part of the risk with an external party, such as through contractual arrangements or insurance.
Risk Retention	Accept and retain the risk when it falls within the organization's defined risk acceptance criteria.

Risk treatment decisions should be documented and approved by the appropriate risk owner or governance authority.

12. Risk Acceptance

Residual risks that remain after treatment must be formally reviewed against VertexOne's risk acceptance criteria.

Risk acceptance should be:

- Documented in the Risk Register.
- Approved by the appropriate risk owner.
- Supported by a clear business justification.
- Subject to periodic review.
- Reassessed when significant changes occur.

13. Methodology Governance

The Risk Assessment Methodology should be reviewed periodically to ensure that it remains appropriate for VertexOne's business environment, risk profile, regulatory obligations, technology landscape, and ISMS requirements.

Changes to the methodology should be reviewed and approved through the organization's established governance process.

Prepared by: Junior GRC Analyst
Status: Draft for GRC Manager Review
Document: Risk Assessment Methodology
Organization: VertexOne Digital Services
Reference: ISO/IEC 27001:2022 Clause 6.1